

Vulnerability Assessment & Risk Prioritization

Objective:

To perform a vulnerability assessment on internal lab systems and prioritize identified risks based on severity, exploitability, and potential impact.

Scope of Assessment:

Target System	IP Address	OS
Windows XP Machine	192.168.136.129	Microsoft Windows XP
Metasploitable 2	192.168.136.130	Linux

Tool Used:

Primary Scanner Used:
Nmap 7.95 (nmap -sV --script vuln)

Reason: Used as an alternative to Nessus/OpenVAS for vulnerability detection and CVE mapping.

Scan Results Summary:

Target 1: Windows XP (192.168.136.129)

Open Ports Identified:

Port	Service
139	NetBIOS
445	SMB
3389	RDP

Critical Vulnerabilities Identified:

MS08-067 – Windows Server Service RCE

CVE-2008-4250:

- Affects: SMB (Port 445)
- Type: Remote Code Execution
- CVSS Score: 10.0 (Critical)
- Authentication Required: No
- Impact: Full SYSTEM access

Risk Level: **CRITICAL**

Priority: 1 (Highest)

MS17-010 – EternalBlue Vulnerability

CVE-2017-0143

- Affects: SMBv1 (Port 445)
- Type: Remote Code Execution
- CVSS Score: 9.8 (Critical)
- Exploited by: WannaCry

Risk Level: **CRITICAL**

Priority: 2

Risk Analysis (Windows XP):

The SMB service exposes unauthenticated remote code execution vulnerabilities. An attacker can gain complete control of the system remotely.

System is highly vulnerable and unsafe for production use.

Target 2: Metasploitable 2 (192.168.136.130)

Open Ports Identified:

Port	Service
21	FTP (vsftpd 2.3.4)
22	SSH (OpenSSH 4.7p1)

Critical Vulnerabilities Identified:

vsFTPD 2.3.4 Backdoor:

CVE-2011-2523

- Port: 21
- Type: Backdoor Remote Access
- CVSS Score: 10.0 (Critical)
- Exploit Result: Root shell obtained (uid=0(root))

Risk Level: **CRITICAL**
Priority: 1 (Highest on this host)

Impact: Attacker gains direct root access without authentication.

OpenSSH Vulnerabilities:

CVE-2023-38408
CVE-2016-1908

- Port: 22
- Type: Remote Code Execution / Information Disclosure
- Severity: High
- Exploit References: Public exploit databases available

Risk Level: **HIGH**
Priority: 2

Risk Classification Method:

Vulnerabilities were classified using:

- CVSS Score
- Exploit availability
- Authentication requirement
- Impact severity

Severity Level	CVSS Range
Critical	9.0 – 10
High	7.0 – 8.9
Medium	4.0 – 6.9
Low	0.1 – 3.9

Risk Prioritization (Overall):

Rank	Vulnerability	CVE	System	Severity
1	MS08-067	CVE-2008-4250	Windows XP	Critical
2	MS17-010	CVE-2017-0143	Windows XP	Critical
3	vsFTPD Backdoor	CVE-2011-2523	Metasploitable	Critical

4	OpenSSH Vulnerabilities	CVE-2023- 38408	Metasploitable	High
---	----------------------------	--------------------	----------------	------

Recommended Remediation:

For Windows XP:

- Apply MS08-067 and MS17-010 patches
- Disable SMBv1
- Block Port 445 via firewall
- Upgrade to supported Windows OS (XP is end-of-life)

For Metasploitable 2:

- Upgrade vsftpd to latest version
- Remove compromised FTP service
- Update OpenSSH
- Restrict SSH access using firewall
- Disable unnecessary services